BL-05 Permission Matrix

Backlog item: BL-05 (GitHub issue #5) | Sprint 1 | Implemented in `apps/accounts/permissions.py`.

The server checks every request (SEC-10). Hiding a button or link is never the only protection.

How access is decided

1. **Login.** Every page requires a login except the home page and the login page (SEC-01).
2. **Role.** The role must be allowed the action in the matrix below.
3. **Scope.** The record must be within the user's scope: Faculty only their assigned classes, Students only themselves (SEC-12, SEC-13).

A refused request shows **"Access denied"** (HTTP 403), returns no protected data, changes nothing, and is written to the audit log with the user, time and page (SEC-12, SEC-22). A record that does not exist at all shows "Not found" (404).

Matrix

yes = allowed | yes own = allowed only within the user's scope | - = denied

Action	Admin	Faculty	Student	Source
Create, reset, deactivate, delete accounts	yes	-	-	AR-01, AR-02
Reset another user's OTP (two-factor login)	yes after re-entering own password	-	-	SEC-31, BL-01 D-21
Add, update, deactivate, reactivate, delete student records	yes	-	-	FR-03, AR-02
View student details	yes	yes own classes	yes own profile (read-only)	FR-03, AR-02
Manage faculty records	yes	-	-	FR-04, SEC-14
Create subjects	yes	yes	-	FR-05
Edit subjects	yes	yes subjects they teach	-	FR-05, BL-05 decision
Delete subjects	yes	-	-	BL-05 decision, BL-01 D-05
Manage sections, enrolments, teaching assignments	yes	-	-	FR-06, SEC-14
Mark attendance	yes missed sessions, with reason	yes own classes	-	FR-07, AR-08, SEC-13
Correct attendance	yes any record, with reason	yes own classes, within window	-	FR-08, AR-08, SEC-13
View attendance	yes	yes own classes	yes own records	FR-09, SEC-12, SEC-13
View attendance change history	yes	yes own classes	-	FR-18, BL-05 decision
Generate reports	yes	yes own classes	-	FR-12, UC-09
Export reports (PDF/CSV)	yes	yes own classes	-	FR-16, SEC-24
Search and filter records	yes	yes own classes	-	FR-15, UC-11
Configure attendance threshold	yes	-	-	SEC-14
Configure faculty correction window	yes with reason	-	-	BL-01 D-09, SEC-23, BL-17
View below-threshold list	yes	yes own classes	-	FR-13, AR-14
View own low-attendance notifications	-	-	yes own	FR-14, AR-13, BL-23
Backup and restore	yes	-	-	FR-19, SEC-26
View full audit log	yes	-	-	SEC-21

Action	Admin	Faculty	Student	Source
Own dashboard	yes Admin	yes Faculty	yes Student	FR-17, UC-01

A deactivated account has no permissions and cannot log in (SEC-15). The Django admin site (`/admin/`) is limited to staff superusers created with `createsuperuser`.

Decisions made in BL-05 (approved 20 Oct 2026)

Topic	Decision
Subjects	Faculty may create subjects and edit the subjects they teach; only the Admin deletes subjects or links them to sections. FR-05 and UC-04 are unchanged.
Refused requests	Show "Access denied" and log the attempt, matching SEC-12.
Attendance change history	Admin sees all; Faculty see their own classes; Students see none (they see their current attendance in FR-09).

Using the rules in later backlog items

Need	Use
Protect a page by action	`@requires("attendance.mark")`
List only what the user may see	`visible_students(user)`, `visible_assignments(user)`, `visible_attendance_records(user)`, `visible_attendance_history(user)`
Open one record by ID from the URL	`get_visible_or_deny(visible_attendance_records(user), AttendanceRecord, pk)`
Check a change before saving	`can_mark_attendance(user, assignment)`, `can_correct_attendance(user, record)`, `can_edit_subject(user, subject)`

The correction service enforces the saved BL-17 calendar-day window under database locks. The same setting controls faculty creation of missed sessions. Admin changes to the window require a reason and are audited.

Verification

`apps/accounts/test_permissions.py` checks every cell of the matrix for all three roles, the scope rules with two classes taught by different faculty, ID tampering by a student, login-required on every page, and that refused requests are logged without changing data. `apps/accounts/test_django_admin.py` covers the Django admin account pages.